Device Security and Endpoint Policy

Document ID	SEC-004
Department	IT and Information Security
Document type	Policy
Owner	Head of IT Operations
Version	3.3
Status	APPROVED
Effective / last reviewed	2026-01-22
Audience	All employees and contractors
Related documents	SEC-003, OPS-007, HR-003, SEC-010

Summary. Policy for securing laptops, phones and other endpoints at Northstar. Covers company-only laptops, mandatory disk encryption, screen lock, BYOD rules, lost or stolen device reporting and remote wipe, USB blocking, OS patch timelines, admin rights, refresh and disposal.

SYNTHETIC DOCUMENT - Northstar Systems is a fictional company. This document exists for development, testing and demonstration only and is not real legal, employment, security or compliance advice.

1. Purpose and Scope

This policy sets the minimum security requirements for every device that stores, processes or accesses Northstar information. It implements SEC-001 (Information Security Policy) at the endpoint level and works with SEC-003 (Password and Authentication Standard) and SEC-007 (Vulnerability and Patch Management Procedure). It applies to all employees, contractors and third parties using company laptops, desktops, tablets and phones, and to personal phones enrolled for limited work use, at the Whitefield and Powai offices, at home and while travelling.

The policy is owned by the Head of IT Operations, who runs endpoint management through NorthGuard. Security Operations monitors device health in NorthGuard and NorthWatch. Legal and regulatory references are illustrative and must be verified by Legal before external use.

2. Definitions

- **Company device**: a laptop, desktop or phone purchased by Northstar and recorded with an asset tag in the form NS-AST- followed by six digits.
- **NorthGuard**: the endpoint management (MDM) platform that enrols devices, enforces settings and reports encryption and patch status.
- **BYOD**: a personally owned phone enrolled in NorthGuard mobile management.
- **Full-disk encryption**: encryption of the whole storage volume so data is unreadable without authentication.
- **Remote wipe**: a command through NorthGuard that erases a device.
- **Standard user**: a user without local administrator rights.
- **Removable media**: USB drives, external disks and memory cards.
- **Security Desk**: security@northstar-systems.example, hotline extension 5555.
- **IT Service Desk**: extension 4000, the contact for device faults, replacements and requests via NorthDesk.

3. Roles and Responsibilities

Role	Responsibility
Head of IT Operations	Owns this policy, device lifecycle, procurement standards and NorthGuard operations
Security Engineering Manager	Defines device security baselines and reviews exceptions with the CISO delegate
IT Service Desk	Issues, enrols, replaces and wipes devices, and logs incidents in NorthDesk
Security Desk	Receives loss or theft reports within 1 hour, coordinates remote wipe
Finance Controller	Approves write-offs of lost or disposed assets
Reporting managers	Ensure team members comply and approve exceptions requests
All device users	Protect devices, keep them updated, and report loss or damage promptly

4. Company Laptops Only

Company work must be done only on company laptops. Personal laptops, home PCs and unmanaged devices must not be used to access Northstar systems or store Northstar data. This rule exists because Northstar can verify encryption, patch level and software only on managed devices.

1 Every laptop is enrolled in NorthGuard before it leaves the IT Service Desk.
2 Software is installed only from the approved catalogue. Users must not install unapproved software, and a request for new software is raised in NorthDesk and reviewed by Security Engineering.
3 Personal use of a company laptop is limited, must not break any policy, and must not involve file-sharing, cracked software or unlicensed content.
4 Family members and friends must not use a company laptop.
5 A contractor who is not issued a company laptop may access only the specific virtual desktop or system approved under SEC-002, and never downloads Confidential or Restricted data.

Example: A Support Engineer working from home finds his laptop is in repair and wants to answer a P1 ticket on his personal laptop. This is not allowed. He must call the IT Service Desk (extension 4000), who will issue a loaner laptop or, for a P1, a temporary NorthGuard-enrolled device, and the work continues on that.

5. Mandatory Security Baseline

Every company laptop must meet the following baseline at all times, verified continuously by NorthGuard.

Control	Requirement
Full-disk encryption	Mandatory, reported by NorthGuard. A device that is not encrypted is blocked from corporate systems
Screen lock	Locks after 5 minutes of inactivity and requires sign-in
Operating system patches	Installed within 14 days of release
Endpoint protection	Anti-malware active and signature updates current
Admin rights	Not given to standard users

Control	Requirement
Firewall	Enabled and managed centrally
Removable media	USB mass storage blocked by default
Sign-in	NorthID with MFA; device password meets SEC-003

A device that falls out of the baseline gets a warning in NorthGuard. After 5 business days of non-compliance, it loses access to corporate systems through NorthID conditional access until it is fixed. The user's manager is informed.

5.1 Encryption

Full-disk encryption is mandatory on all laptops and phones that hold company data. Recovery keys are escrowed in NorthGuard and accessible only to the IT Service Desk after identity verification. Users must not disable encryption, and a device must not be sent for repair without informing the IT Service Desk, which may require removing the drive or taking a backup first.

5.2 Screen lock

Screens must lock after 5 minutes of inactivity. Users must also lock manually, using the keyboard shortcut, whenever they leave the device, even in the office. The 5-minute setting cannot be extended by users. Shared screens in meeting rooms must not show Confidential content to visitors.

5.3 Administrator rights

Standard users do not have local administrator rights. A developer who needs elevated rights for a specific task raises a NorthDesk request; the Head of IT Operations or a delegate may approve temporary elevation of at most 8 hours through NorthGuard. Permanent admin rights are not granted. Tools that need admin rights to run are packaged and deployed by IT Operations.

5.4 Compliance monitoring and reporting

NorthGuard reports every device's encryption, patch, protection and enrolment status. The Head of IT Operations reviews a compliance dashboard each week, and Security Operations raises a NorthDesk ticket for any device that stays non-compliant beyond the 5 business day grace period. A monthly compliance summary goes to the CISO and is a standing item at the quarterly security review chaired under SEC-001. The target is at least 98 percent of devices fully compliant, and the remaining devices must each have a documented reason and a plan.

Employees who find that a device shows as non-compliant should first restart it to allow pending updates, then contact the IT Service Desk on extension 4000 if the warning remains. Deferring an update repeatedly is not permitted: after 3 deferrals the update installs at the next restart. Employees must not block NorthGuard, remove its agent, or use a virtual machine to bypass controls.

5.5 Software and cloud applications

Only software on the approved catalogue may be installed. Browser extensions that read page content, remote-control tools and file-sharing clients need Security Engineering approval. Only tools on the Approved AI Tools list may be used for work, and Confidential or Restricted data must never be entered into external AI tools. Cloud storage accounts that are not provided by Northstar must not be used to hold company files. Employees must not synchronise company folders to personal cloud storage.

Example: A designer wants to install a free screen-recording extension that asks to read all web pages. Because the extension reads page content, it needs approval from Security Engineering. She raises a request in NorthDesk; the team reviews the publisher and permissions in 3 business days and approves a different, approved tool instead.

6. Mobile Phones and BYOD

Personal phones may access email and NorthID only, and only after enrolment in NorthGuard mobile management. BYOD phones must:

1 Use a passcode and biometric lock, with auto-lock within 5 minutes.
2 Use full-device encryption (default on modern phones).
3 Run a supported operating system version, with patches applied within 14 days of release.
4 Keep corporate email and NorthID inside the managed work profile. Corporate data must not be copied to personal apps.
5 Not be rooted or jailbroken.

On loss, resignation or non-compliance, Northstar may remove only the work profile and its data from a BYOD phone. A full wipe of a personal phone is not performed unless the user consents. BYOD phones must not be used for access to production, source code or Restricted data. Company-issued phones follow the same baseline and may be fully wiped.

7. Lost, Stolen or Damaged Devices

7.1 Reporting

1 A lost or stolen device must be reported to the Security Desk within 1 hour of discovery, by phone on extension 5555 or by email. Do not wait to search for it.
2 The device loss or damage must also be reported to the IT Service Desk within 24 hours, so a NorthDesk ticket exists and a replacement can be arranged.
3 If the device was stolen, the employee also files a police report and shares the reference number with the Security Desk.

Summary of the key timelines for an incident involving a device:

Event	Report to	Deadline
Lost or stolen device discovered	Security Desk	Within 1 hour of discovery
Lost, stolen or damaged device	IT Service Desk	Within 24 hours
Remote wipe after confirmed loss	Security Desk and NorthGuard	Within 4 hours of confirmation
Device not returned after leaving	IT Service Desk	Treated as lost after 5 business days

A report made late is still accepted and must never be withheld for fear of blame, but the delay is noted and may be considered in the HR review. Where in doubt about whether a device is lost, report it anyway: a device that is later found can be re-enrolled at no penalty to the user.

7.2 Response

1 The Security Desk confirms the report, locks the account sessions in NorthID and revokes tokens.
2 A remote wipe is performed within 4 hours of confirmed loss. If the device is offline, the wipe command stays queued and runs the moment it reconnects. The device is also barred from corporate access.

3 Security Operations reviews recent activity in NorthWatch. If Restricted data was on an unencrypted device, a security incident is declared under SEC-001 and the Privacy Officer decides about personal-data breach notification.
4 The IT Service Desk issues a replacement laptop and restores data from the approved backups.
5 HR reviews the circumstances. Damage or loss caused by negligence may be recovered from the employee after HR review. A first, promptly reported accidental loss is not recovered.

Example: An employee leaves a company laptop in a train at 19:40 and realises at 21:00. She phones extension 5555 at 21:10, which is within the 1-hour limit. The Security Desk confirms at 21:25. The wipe is completed by 01:25, which is within the 4-hour limit, and she emails the IT Service Desk the next morning, within 24 hours. Because the laptop was encrypted and reported promptly, no data breach is declared.

Example: A laptop is dropped and the screen is broken. This is damage rather than loss, so the employee informs the IT Service Desk within 24 hours. No Security Desk report is needed unless the device cannot be accounted for.

8. Removable Media and Peripherals

USB mass storage is blocked by default on all company laptops. If a business need exists (for instance, a customer insists on delivering a signed file on a USB drive), the requester raises an exception in NorthDesk. The CISO delegate must approve, and the exception lasts at most 30 days. The exception lists the named device and user, and the media must be scanned before use, encrypted if it will hold Confidential data, and handed back or wiped afterwards. Keyboards, mice, displays and headsets are allowed. Personal phones must not be connected to company laptops for charging if they open as storage.

Unapproved devices such as personal routers, network hubs and wireless access points must not be connected to the corporate network. Guest Wi-Fi is available for personal devices and is isolated from the corporate network.

9. Working Remotely and Travelling

- Remote and hybrid staff must connect to internal applications through the NorthTunnel VPN with MFA.
- Public Wi-Fi may be used only with NorthTunnel connected.
- Laptops must not be left unattended in cars, hotel rooms or checked baggage.
- Shoulder surfing is a risk: use a privacy screen in public places and do not discuss Confidential matters aloud.
- Working from a location other than the registered city for more than 10 working days in a year requires HR and Security approval.
- For international travel, employees should take only the data they need and report any border-inspection request for the device to the Security Desk.

10. Lifecycle, Refresh and Disposal

1 Standard laptops are refreshed every 48 months. A device may be replaced earlier if it fails or can no longer receive security updates.
2 Each device carries an asset tag in the form NS-AST- followed by 6 digits. The asset register is maintained by IT Operations and reconciled every year.

3 Returning devices: leavers return all company devices on or before the last working day. Access is disabled by 18:30 IST that day (see SEC-002). If a device is not returned within 5 business days, it is treated as lost.
4 Disposal is only through a certified e-waste vendor that provides a data-wipe certificate for each device. The IT Service Desk must not give old devices to staff or donate them.
5 Write-off of a lost or disposed asset needs approval of the Finance Controller. See OPS-007 for the asset management process.

11. Exceptions and Escalation

Exceptions to this policy are raised in NorthDesk. The requester states the control affected, the business reason, compensating controls and the end date. The CISO delegate approves, and the maximum duration of an exception is 90 days unless this policy states a shorter period (such as 30 days for USB mass storage). Exceptions can never allow personal laptops for company work, unencrypted laptops, or an unmanaged phone to access production or Restricted data.

Issues about devices are escalated to the Head of IT Operations; security concerns go to the Security Engineering Manager and then the CISO.

12. Frequently Asked Questions

- Can I use my personal laptop if my company laptop is being repaired? No. Ask the IT Service Desk for a loaner device.
- How soon must I report a stolen laptop? To the Security Desk within 1 hour of discovery, and to the IT Service Desk within 24 hours.
- Can I use a USB drive to copy files? Not by default. Raise an exception, which the CISO delegate may approve for up to 30 days.
- How long do I have to install OS updates? Within 14 days of release. Critical security patches may be pushed faster under SEC-007.
- Will Northstar wipe my personal phone? Only the work profile is removed unless you agree to a full wipe.

13. Related Documents

See SEC-003 for authentication on devices, OPS-007 for asset management and HR-003 for the exit process that requires returning devices. See SEC-010 for related security procedures and SEC-007 for patching timelines.

14. Revision History

Version	Date	Change
3.1	2025-05-20	Added BYOD work-profile rules
3.2	2025-09-15	Clarified lost device reporting and remote wipe timeline
3.3	2026-01-22	Updated USB exception, refresh cycle and disposal wording